

HCL AppScan Report

Report Type: Security Report

Scan Name: Supply Chain Rapid Diagnostics Factory_2026-06-01_11-08-24

Technology: SAST

Report created at: Tuesday, June 2, 2026

This report was generated by HCL AppScan

Summary of security issues

High severity issues: 10

Total security issues: 10

Scan Information

Scan started: Monday, June 1, 2026 12:47:17 PM (UTC)

Table of Contents

Summary

- Issues

Fix-Groups

- Common API Call: [Authentication.Credentials.Unprotected](#): Secrets: Hardcoded credentials detected
- Common API Call: [Authentication.Credentials.Unprotected](#): Secrets: Potential Azure Shared Access Signatures (SAS) token exposure detected
- Common API Call: [PrivilegeEscalation](#): No non-root USER specified in Dockerfile configuration
- Common Fix Point:SSRF: response = await fetch(`\$
- Common Fix Point:URL Validation Required: if (!unlockedTabs.includes(selectedTab))
- Common Fix Point:URL Validation Required: tabPage

How to Fix

- [Authentication.Credentials.Unprotected](#) - Secrets: Potential Azure Shared Access Signatures (SAS) token exposure detected
- [Authentication.Credentials.Unprotected](#) - Secrets: Hardcoded credentials detected
- [PrivilegeEscalation](#) - No non-root USER specified in Dockerfile configuration
- SSRF
- URL Validation Required

Summary

Total security issues: **10**

Issue Types: **4**

		Number of Issues
Authentication.Credentials.Unprotected	3	
PrivilegeEscalation	1	
SSRF	1	
URL Validation Required	5	

Critical High Medium Low Informational

Issues - By Fix Groups:

H	Common API Call: Authentication.Credentials.Unprotected: Secrets: Hardcoded credentials detected
Fix Group ID:	3e3d997a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:50:34Z
API:	Secrets: Hardcoded credentials detected
How to Fix:	Secrets: Potential Azure Shared Access Signatures (SAS) token exposure detected

Issue 1 of 2

Issue ID:	943d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	3e3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\k8s\secret.yaml:9
Line	9
Source File	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\k8s\secret.yaml
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	522
API:	Secrets: Hardcoded credentials detected
Caller:	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\k8s\secret.yaml:9

Issue 1 of 2 - Details

Call

DB_USER: "rapidsqladmin"

Issue 2 of 2

Issue ID:	973d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	3e3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\k8s\secret.yaml:10
Line	10
Source File	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\k8s\secret.yaml
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	522
API:	Secrets: Hardcoded credentials detected
Caller:	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\k8s\secret.yaml:10

Issue 2 of 2 - Details

Call

DB_PASSWORD: "Pk\$q1bd#p2g54hn"

H	Common API Call: Authentication.Credentials.Unprotected: Secrets: Potential Azure Shared Access Signatures (SAS) token e...
Fix Group ID:	453d997a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:50:34Z
API:	Secrets: Potential Azure Shared Access Signatures (SAS) token exposure detected
How to Fix:	Secrets: Potential Azure Shared Access Signatures (SAS) token exposure detected

Issue 1 of 1

Issue ID:	913d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	453d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\k8s\frontend-deployment.yaml:37
Line	37
Source File	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\k8s\frontend-deployment.yaml
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	522
API:	Secrets: Potential Azure Shared Access Signatures (SAS) token exposure detected
Caller:	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\k8s\frontend-deployment.yaml:37

Issue 1 of 1 - Details

Call

?sp=r&st=2026-05-15T14:32:52Z&se=2031-10-17T22:47:52Z&spr=https&sv=2025-11-05&sr=c&sig=yMCPnNFO9nDUMMsov53I2WWWwl1nf8cv715xzZ0cwxk%3D"
--

H	Common API Call: PrivilegeEscalation: No non-root USER specified in Dockerfile configuration
Fix Group ID:	413d997a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:50:34Z
API:	No non-root USER specified in Dockerfile configuration
How to Fix:	No non-root USER specified in Dockerfile configuration

Issue 1 of 1

Issue ID:	853d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	413d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\Dockerfile:1
Line	1
Source File	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\Dockerfile
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	266
API:	No non-root USER specified in Dockerfile configuration
Caller:	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\Dockerfile: 1

Issue 1 of 1 - Details

Call

Multi-stage Dockerfile for building and serving the React fronten d
--

H	Common Fix Point:SSRF: response = await fetch(` \$
Fix Group ID:	9b8f5b90-da58-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-05-26 08:12:02Z
Location of fix:	response = await fetch(` \$
How to Fix:	SSRF

Issue 1 of 1

Issue ID:	733d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	9b8f5b90-da58-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:32
Line	32
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	918
Source:	response = await fetch(`\${SAFE_API_BASE}/capabilities`) <i>via</i> Supply Chain Rapid Diagnostics Factory/ LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:49
Sink:	<i>via</i> Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:3 2

Issue 1 of 1 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:4
9
response = await fetch(`\${SAFE\_API\_BASE}/capabilities`)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:4
8
async () => {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:2
4
export const apiService = {...async () => {
const response = await fetch(`\${SAFE\_API\_BASE}/capabilities`);
return handleResponse(response);
}...};
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:2
8
async (year = "2024") => {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:3
0
/^d{4}\$/.test(String(year))
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:3
0
safeYear = /^d{4}\$/.test(String(year)) ? String(year) : "2024"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:3
2
fetch(`\${SAFE\_API\_BASE}/\${safeYear}`)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/api.js:3
2
response = await fetch(`\${SAFE\_API\_BASE}/\${safeYear}`)

H	Common Fix Point:URL Validation Required: if (!unlockedTabs.includes(selectedTab))
Fix Group ID:	443d997a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:50:34Z
Location of fix:	if (!unlockedTabs.includes(selectedTab))
How to Fix:	URL Validation Required

Issue 1 of 1

Issue ID:	5e3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	443d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:685
Line	685
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425
Source:	rawTab = params.get("tab") "Templates" v/a Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:72
Sink:	v/a Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:685

Issue 1 of 1 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:72

rawTab = **params.get("tab")** || "Templates"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:73

selectedTab = ALLOWED_TABS.has(**rawTab**) ? **rawTab** : "Templates"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407

if (!unlockedTabs.includes(**selectedTab**)) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:685

navigate(`?tab=\${**selectedTab**}`)

H	Common Fix Point:URL Validation Required: tabPage
Fix Group ID:	3f3d997a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:50:34Z
Location of fix:	tabPages
How to Fix:	URL Validation Required

Issue 1 of 4

Issue ID:	5b3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	3f3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:590
Line	590
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425
Source:	rawTab = params.get("tab") "Templates" <i>via</i> Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:72
Sink:	<i>via</i> Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:590

Issue 1 of 4 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js	x
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:72	rawTab = params.get("tab") "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:73	selectedTab = ALLOWED_TABS.has(rawTab) ? rawTab : "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:175	isKpiCalcActive = selectedTab === "KPI-calculation"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:213	isWaterfallPage = isKpiCalcActive && currentPage === 2
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:225	useGetKpiWaterfallDataQuery(waterfallArgs, {...isWaterfallPage...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:221	waterfallData
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:499	getTabConfig({...waterfallData...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:499	tabConfig = getTabConfig({...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571	tabContent
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571	tabPages
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:578	tabs = Object.keys(tabPages)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:590	navigate(`?tab=\${ <b>tabs</b> [currentIndex]}`)

Issue 2 of 4

Issue ID:	523d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	3f3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:588
Line	588
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425
Source:	rawTab = params.get("tab") "Templates" <i>via</i> Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:72
Sink:	<i>via</i> Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:588

Issue 2 of 4 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js	x
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:2	rawTab = params.get("tab") "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:3	selectedTab = ALLOWED_TABS.has(rawTab) ? rawTab : "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:175	isKpiCalcActive = selectedTab === "KPI-calculation"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:13	isWaterfallPage = isKpiCalcActive && currentPage === 2
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:25	useGetKpiWaterfallDataQuery(waterfallArgs, {...isWaterfallPage...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:21	waterfallData
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:99	getTabConfig({...waterfallData...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:99	tabConfig = getTabConfig({...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571	tabContent
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571	tabPages
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:578	tabs = Object.keys(tabPages)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:582	nextTab = tabs [nextIndex]
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:583	if (!unlockedTabs.includes(nextTab)) {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:584	dispatch(unlockTab(nextTab))
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:587	safeNext = ALLOWED_TABS.has(nextTab) ? nextTab : "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:588	navigate(`?tab=\${ <b>safeNext</b> }`)

Issue 3 of 4

Issue ID:	6d3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	3f3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:888
Line	888
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425
Source:	rawTab = params.get("tab") "Templates" <i>via</i> Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:72
Sink:	<i>via</i> Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:888

Issue 3 of 4 - Details

Trace

```
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js
x
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:7
2 rawTab = params.get("tab") || "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:7
3 selectedTab = ALLOWED_TABS.has(rawTab) ? rawTab : "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:1
75 isKpiCalcActive = selectedTab === "KPI-calculation"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:2
13 isWaterfallPage = isKpiCalcActive && currentPage === 2
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:2
25 useGetKpiWaterfallDataQuery(waterfallArgs, {...isWaterfallPage...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:2
21 waterfallData
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
99 getTabConfig({...waterfallData...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
99 tabConfig = getTabConfig({...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
71 tabContent
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
71 tabPage
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:8
72 Object.keys(tabPages).map((tab, idx) => {...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:8
72 (tab, idx) => {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:8
75 isVisited = visitedTabs.has(tab) && selectedTab !== tab
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:8
87 safeTab = ALLOWED_TABS.has(tab) ? tab : "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:8
88 navigate(`?tab=${safeTab}`)
```

Issue 4 of 4

Issue ID:	643d997a-b85d-f111-8fcb-0022484e63bd
Severity:	High
Status	Open
Fix Group ID:	3f3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:805
Line	805
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425
Source:	rawTab = params.get("tab") "Templates" via Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:72
Sink:	via Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:805

Issue 4 of 4 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js
x

```
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:7
2
rawTab = params.get("tab") || "Templates"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:7
3
selectedTab = ALLOWED_TABS.has(rawTab) ? rawTab : "Templates"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:1
75
isKpiCalcActive = selectedTab === "KPI-calculation"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:2
13
isWaterfallPage = isKpiCalcActive && currentPage === 2

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:2
25
useGetKpiWaterfallDataQuery(waterfallArgs, {...isWaterfallPage...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:2
21
waterfallData

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
99
getTabConfig({...waterfallData...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
99
tabConfig = getTabConfig({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
71
tabContent

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
71
tabPages

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:7
98
tabs = Object.keys(tabPages)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:8
02
ALLOWED_TABS.has(tabs[prevIndex])

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:8
02
safePrev = ALLOWED_TABS.has(tabs[prevIndex])
? tabs[prevIndex]
: "Templates"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:8
05
navigate(`?tab=${safePrev}`)
```

How to Fix

H Authentication.Credentials.Unprotected - Secrets: Potential Azure Shared Access Signatures (SAS) token exposure detected

Cause

If a SAS is leaked, it can be used by anyone who obtains it, which can potentially compromise your storage account. If a SAS provided to a client application expires and the application is unable to retrieve a new SAS from your service, then the application's functionality may be hindered.

Fix recommendation

Shared access signatures are keys that grant permissions to storage resources, and you should protect them just as you would protect an account key. It's important to protect a SAS from malicious or unintended use. Use discretion in distributing a SAS, and have a plan in place for revoking a compromised SAS. Operations that use shared access signatures should be performed only over an HTTPS connection, and SAS URIs should be distributed only on a secure connection, such as HTTPS.

External references

- [Delegate access by using a shared access signature](#)

[Go to Table of Contents](#)

H Authentication.Credentials.Unprotected - Secrets: Hardcoded credentials detected

Cause

Hardcoded credentials, such as usernames, passwords, and API Keys are a common security vulnerability. When credentials are hardcoded into an application's source code, they can be exposed to anyone who has access to the code, leading to unauthorized access and data breaches.

Hardcoded credentials pose several risks:

Exposure of sensitive information: If the source code is exposed, either through a repository leak or a simple oversight, anyone can see and use these credentials.

Lack of flexibility: Hardcoded credentials can't be changed without modifying the source code. This makes it difficult to rotate, revoke, or update credentials.

Non-compliance: Many industry regulations and standards require proper management of sensitive information, including credentials.

Fix recommendation

Instead of hardcoding credentials in the source code, consider these alternatives:

Environment variables

Environment variables are a secure way to store sensitive information. They are set in the environment in which the application runs and can be accessed programmatically.

User input

For applications that interact with users, consider prompting for credentials at runtime.

Secure credential storage

Use secure storage solutions like AWS Secrets Manager, Azure Key Vault, or HashiCorp Vault. These tools store credentials securely and provide them to your application as needed.

Configuration files

Store credentials in a configuration file that is not included in the source code repository. Make sure this file is encrypted and protected with appropriate file system permissions.

External references

- [CWE-798: Use of Hard-coded Credentials](#)
- [Use of hard-coded password](#)

[Go to Table of Contents](#)

H PrivilegeEscalation - No non-root USER specified in Dockerfile configuration

Cause

When executing a Docker image, by default the user that runs the process is root. As a best practice, you should run with a user that does not have high privileges; this help prevent privilege escalation. Apple the Principle of Least Privilege (POLP) when building or running a Docker image: give your user only the privileges it needs to perform the intended functions.

```
FROM alpine:3.4
RUN apk update
RUN apk add vim
RUN apk add curl
```

Fix recommendation

To protect against privilege escalation, run with a user that only has enough privileges to perform the intended functions. You can use ROOT to configure your machine and install tools you need, mount driver, create new users and other function that require ROOT access. Then use the Docker USER command to define the user to run the image as. Use either: USER <user>[:<group>] or USER <UID>[:<GID>]

```
FROM alpine:3.4
<In this section you might need to run as ROOT to set up your machine. Install, mount, etc>
RUN groupadd -r myuser && useradd -r -g myuser myuser
RUN apk update
RUN apk add vim
RUN apk add curl
<Once you're done with the actions that need ROOT permissions, switch to your unprivileged user>
USER myuser
```

```
FROM selenium/node-chrome:4.0.0-beta-1-20210215
USER root

RUN apt-get update -qqy \
&& rm -rf /var/lib/apt/lists/* /var/cache/apt/* \
&& rm /bin/sh && ln -s /bin/bash /bin/sh \
&& chown seluser /usr/local

USER myuser
```

External references

- [Docker run documentation](#)

[Go to Table of Contents](#)

H SSRF

Cause

Server-Side Request Forgery (SSRF) occurs when an application fetches a remote resource based on user input without proper validation.

Attackers can manipulate the target URL to make the server perform unintended requests, potentially accessing internal resources or services not intended to be exposed.

Risk

SSRF can lead to unauthorized access to internal systems, data exfiltration, port scanning, and even remote code execution depending on the server's privileges and network configuration.

Exploit example

Example SSRF attack via manipulated URL input.
Expected data from front end service:

```
POST /fetch HTTP/1.1
Host: vulnerable-app.com
Content-Type: application/json
{ "url": "https://example.com/image.png" }
```

What an attacker can craft over the same connection:

```
POST /fetch HTTP/1.1
Host: vulnerable-app.com
Content-Type: application/json
{ "url": "http://localhost:8080/admin" }
```

Fix recommendation

Validate and sanitize all user-supplied URLs before making server-side requests.

Implement allow-lists for permitted domains and block requests to internal IP ranges (e.g., 127.0.0.1, 169.254.169.254, etc.).

Disable unnecessary network protocols and restrict outbound traffic from the application server.

CWE

918

External references

- [OWASP SSRF Prevention Cheat Sheet](#)
- [CWE-918: Server-Side Request Forgery \(SSRF\)](#)
- [SSRF Explained](#)

[Go to Table of Contents](#)

H URL Validation Required

Cause

This API accepts a URL that is supplied by an outside source. If an attacker is able to manipulate the URL, that attacker could cause legitimate users to fall victim to phishing attacks by redirecting the user to a seemingly legitimate website. If the user thinks that this impostor website is valid, the user may be tricked into submitting login credentials or other type of user information. The impostor website would then send this data to the attacker.

Another attack vector would be for an attacker to submit a URL that points to a website that hosts Trojans and other types of malware. If a user is tricked into browsing to this URL, or somehow submitting an HTTP request to this URL, the user's computer may be infected with the Trojans or other malware.

Fix recommendation

It is critical that the URL is validated to point to a legitimate resource. This can be accomplished with a hard coded whitelist of acceptable url paths as well as sanitizing the URL query parameters.

